

Encuesta FAIR de Ciber-Riesgo para Organizaciones

1. Datos generales de la organización

1.1 Nombre de la organización (opcional).

1.2 Sector principal de actividad.

- Energía y utilities
- Finanzas y seguros
- Telecomunicaciones y tecnología
- Sanidad y farmacéutico
- Industria y manufactura
- Administración pública
- Otros (especificar)

1.3 Tamaño aproximado de la organización (empleados).

- Menos de 50
- 50–249
- 250–999
- 1.000–4.999
- 5.000 o más

1.4 Ámbito geográfico principal de operación.

- España únicamente
- España y Unión Europea
- Global (presencia fuera de la UE)

1.5 Rol de la persona que responde.

- CISO / Responsable de seguridad de la información
- CIO / CTO
- Responsable de Riesgos / CRO
- Responsable de Cumplimiento / Legal
- Dirección General
- Otra función (especificar)

2. Gobernanza del riesgo según FAIR

2.1 ¿Conoce su organización el marco FAIR (Factor Analysis of Information Risk)?

- No, nunca lo habíamos oído
- Sí, lo conocemos de forma general pero no lo usamos
- Sí, lo usamos de forma puntual para algunos análisis
- Sí, es el marco principal para cuantificar el ciber-riesgo

2.2 ¿Existe una política formal que obligue a cuantificar el ciber-riesgo en términos económicos (por ejemplo, pérdida esperada anual en euros)?

- No existe
- Existe de forma informal o ad hoc
- Existe, pero se aplica solo en proyectos relevantes
- Existe y se aplica de forma sistemática en toda la organización

2.3 ¿Qué órganos de gobierno revisan los resultados de análisis de riesgo basados en FAIR o modelos equivalentes?

- Ninguno; se revisa a nivel técnico únicamente
- Comité de Seguridad / Riesgos operativo
- Comité de Dirección
- Consejo de Administración o Comisión de Auditoría
- Otros (especificar)

2.4 ¿Con qué frecuencia se presenta al máximo órgano de gobierno una visión cuantitativa del ciber-riesgo (en euros, percentiles de pérdida, etc.)?

- Nunca
- Menos de una vez al año
- Una vez al año
- Dos veces al año
- Trimestralmente o más frecuente

2.5 ¿Se vinculan los resultados de los análisis FAIR con los objetivos estratégicos o el apetito de riesgo de la organización?

- No se vinculan en absoluto
- Se mencionan de forma cualitativa
- Se vinculan con límites o umbrales generales
- Se vinculan explícitamente con métricas de apetito y tolerancia al riesgo

3. Alcance y madurez en el uso de FAIR

3.1 ¿En qué medida utiliza su organización FAIR u otro modelo cuantitativo similar para evaluar el ciber-riesgo?

- No lo utilizamos
- Lo utilizamos solo para casos de negocio o proyectos puntuales
- Lo utilizamos para los principales riesgos de TI
- Lo utilizamos para los riesgos críticos de toda la organización

3.2 ¿Para qué finalidades utiliza principalmente los análisis FAIR?

- Justificar inversiones en controles de seguridad
- Negociar o revisar pólizas de ciber-seguro
- Cumplimiento normativo y auditorías
- Planificación de continuidad de negocio y resiliencia

- Priorizar la remediación de vulnerabilidades
- Otros (especificar)

3.3 ¿En qué dominios se aplican habitualmente los análisis FAIR?

- Sistemas de información corporativos (IT)
- Tecnología operativa / redes industriales (OT)
- Datos personales y privacidad
- Servicios en la nube
- Proveedores y cadena de suministro
- Otros (especificar)

3.4 ¿Qué nivel de formalización tienen los parámetros clave de FAIR (LEF, LM, TEF, vulnerabilidad, etc.)?

- Se estiman de forma informal por expertos
- Se documentan con rangos y supuestos claros
- Se sustentan en datos históricos internos
- Se sustentan en datos internos y fuentes externas (inteligencia de amenazas, estudios sectoriales)

3.5 ¿Qué herramientas utiliza para implementar los modelos FAIR?

- Hojas de cálculo internas
- Herramientas desarrolladas internamente
- Plataformas comerciales específicas de cuantificación de riesgo
- Servicios de consultoría externa
- No aplicable

4. Indicadores de frecuencia (LEF, TEF, vulnerabilidad)

4.1 ¿Dispone su organización de un registro centralizado de incidentes de seguridad que se utilice para estimar frecuencias de eventos de pérdida (LEF)?

- No existe un registro sistemático
- Existe, pero no se usa para análisis cuantitativo
- Existe y se usa parcialmente para estimar LEF
- Existe, se usa de forma sistemática y se revisa periódicamente

4.2 ¿Qué fuentes utiliza para estimar la frecuencia de eventos de amenaza (TEF)?

- Opinión de expertos internos
- Informes de inteligencia de amenazas de terceros
- Estadísticas sectoriales o nacionales
- Datos propios de ataques bloqueados / detectados
- No se estima explícitamente

4.3 ¿Cómo se determina la vulnerabilidad (probabilidad de que un evento de amenaza se convierta en pérdida)?

- Solo por juicio experto

- Mediante inventarios de activos y evaluaciones de controles
- Mediante indicadores de exposición (por ejemplo, superficie de ataque, criticidad de activos)
- Mediante modelos que combinan controles, amenazas y exposición

4.4 ¿Se utilizan distribuciones de probabilidad (por ejemplo, mínimos, máximos y valores más probables) para modelar la frecuencia de incidentes?

- No, solo valores puntuales
- A veces, en escenarios especiales
- Sí, de forma habitual en todos los análisis

4.5 ¿Con qué frecuencia se revisan y actualizan las estimaciones de LEF y TEF?

- Menos de una vez cada dos años
- Cada uno o dos años
- Al menos una vez al año
- Varias veces al año o tras incidentes relevantes

5. Indicadores de magnitud de pérdida (LM)

5.1 ¿Cuáles de las siguientes formas de pérdida se cuantifican habitualmente en sus análisis?

- Pérdida de productividad (tiempos de parada, degradación de servicio)
- Costes de respuesta y recuperación
- Costes de sustitución, reconstrucción o restauración
- Pérdida de ingresos o de clientes
- Multas y sanciones regulatorias
- Costes derivados de litigios y reclamaciones
- Daño reputacional / impacto de mercado

5.2 ¿Con qué nivel de detalle se cuantifican estos conceptos?

- Estimaciones globales para todo el incidente
- Estimaciones por tipo de pérdida (productividad, sanciones, etc.)
- Estimaciones detalladas por unidad de negocio o servicio

5.3 ¿Se emplean distribuciones de probabilidad para la magnitud de la pérdida (mínimo, máximo, más probable)?

- No, solo estimaciones puntuales
- Sí, de forma limitada en algunos escenarios
- Sí, de forma sistemática en todos los escenarios relevantes

5.4 ¿Qué fuentes de información se utilizan para valorar económicamente las pérdidas?

- Datos contables internos y estados financieros
- Estudios de mercado y análisis sectoriales
- Datos de aseguradoras o reaseguradoras
- Benchmarks internacionales o de asociaciones profesionales
- Solo juicio experto

5.5 ¿Cómo se tratan las pérdidas secundarias (reputación, litigios, sanciones) en sus modelos?

- No se incluyen
- Se incluyen de forma cualitativa
- Se incluyen con estimaciones aproximadas
- Se incluyen mediante modelos cuantitativos específicos

6. Pérdida anual esperada, VaR y métricas financieras

6.1 ¿Calcula su organización la pérdida anual esperada (ALE) para escenarios de ciber-riesgo clave?

- No
- Solo para algunos escenarios críticos
- Sí, para la mayoría de los escenarios relevantes

6.2 ¿Se utilizan percentiles de pérdida (por ejemplo, “pérdida con 95 % de confianza”) similares al valor-en-riesgo financiero?

- No
- Sí, pero solo para uso interno técnico
- Sí, y se presentan a la alta dirección
- Sí, y se integran en modelos de riesgo empresarial global

6.3 ¿Se comparan las pérdidas estimadas por ciber-riesgo con otros riesgos operacionales o financieros?

- No se comparan
- Se comparan de forma cualitativa
- Se comparan mediante indicadores cuantitativos (por ejemplo, en % de ingresos)

6.4 ¿Se utilizan los resultados de FAIR para fijar umbrales de apetito y tolerancia al riesgo?

- No
- Sí, pero de forma informal
- Sí, están formalmente definidos y aprobados

7. Eficacia de controles (FAIR-CAM u otros enfoques)

7.1 ¿Evalúa su organización la contribución específica de los controles de seguridad a la reducción del riesgo (por ejemplo, reducción de TEF o LM)?

- No, solo se mide la existencia o ausencia de controles
- Sí, de forma cualitativa (por ejemplo, “alto, medio, bajo”)
- Sí, mediante métricas cuantitativas (porcentaje de reducción, etc.)

7.2 ¿Se han definido indicadores de capacidad, cobertura y fiabilidad para los controles clave (detección, prevención, respuesta, recuperación)?

- No
- Solo para algunos controles críticos
- Sí, de forma sistemática y documentada

7.3 ¿Se utiliza alguna adaptación de FAIR-CAM para modelar la eficacia de los controles?

- No lo conocemos
- Lo conocemos pero no lo aplicamos
- Lo aplicamos de forma experimental
- Lo aplicamos de forma estructurada

7.4 ¿Con qué frecuencia se revisa el rendimiento real de los controles frente a los supuestos usados en los modelos?

- Nunca
- Ocasionalmente, tras auditorías o incidentes
- Anualmente
- Varias veces al año

8. Materialidad, regulación y reporting

8.1 ¿Utiliza su organización criterios de materialidad para clasificar los incidentes de ciber-riesgo (por ejemplo, en función de ingresos, EBITDA, capitalización)?

- No
- Sí, pero solo con criterios cualitativos
- Sí, con umbrales cuantitativos claros

8.2 ¿Se ha adaptado FAIR o FAIR-MAM para cumplir con requisitos de reporting financiero o regulatorio aplicables a su sector?

- No
- Estamos en fase de análisis
- Sí, parcialmente
- Sí, de forma completa

8.3 ¿Cómo se tienen en cuenta las obligaciones normativas (GDPR, NIS2, ENS, sectoriales) en la estimación de pérdidas?

- No se incluyen explícitamente
- Se incluyen como riesgo cualitativo general
- Se incluyen como escenarios específicos con cuantificación de sanciones y costes

8.4 ¿Se reportan los resultados cuantitativos de ciber-riesgo a reguladores, supervisores o aseguradoras?

- No
- Sí, de forma agregada o anonimizada
- Sí, con detalle por escenario

9. Datos, automatización e IA en el modelo FAIR

9.1 ¿Qué grado de automatización tiene actualmente su proceso de cuantificación de ciber-riesgo?

- Totalmente manual (hojas de cálculo, entrevistas)
- Parcialmente automatizado (algunas fuentes de datos se integran automáticamente)
- Altamente automatizado (uso de plataformas integradas, simulaciones automáticas)

9.2 ¿Utiliza su organización técnicas de simulación (por ejemplo, Monte Carlo) para estimar distribuciones de riesgo?

- No
- Sí, de forma esporádica
- Sí, de forma regular

9.3 ¿Se emplean técnicas de IA o aprendizaje automático para apoyar la estimación de parámetros FAIR (frecuencia, impactos, eficacia de controles)?

- No
- Sí, en fase piloto
- Sí, integradas en el proceso habitual

9.4 ¿Se integran fuentes externas (por ejemplo, inteligencia de amenazas, índices sectoriales, bases de datos de incidentes) de forma automática en los modelos?

- No
- Parcialmente
- Sí, de forma sistemática

10. Integración con continuidad de negocio y resiliencia

10.1 ¿Se utilizan los resultados de los modelos FAIR para priorizar escenarios en los planes de continuidad de negocio y recuperación ante desastres?

- No
- Sí, pero de forma informal
- Sí, como criterio central de priorización

10.2 ¿Se han definido objetivos de tiempo de recuperación (RTO) y punto de recuperación (RPO) coherentes con los niveles de pérdida aceptables derivados de FAIR?

- No
- Parcialmente
- Sí, de forma sistemática

10.3 ¿Se ensayan escenarios de crisis basados en los casos de peor pérdida (percentiles altos de las distribuciones FAIR)?

- No
- Sí, ocasionalmente
- Sí, con ejercicios regulares y participación de la alta dirección

11. Perspectiva sectorial y territorial

11.1 ¿Participa su organización en iniciativas sectoriales o nacionales para compartir datos o métricas de ciber-riesgo cuantitativo?

- No
- Estamos explorándolo
- Sí, participamos activamente

11.2 ¿En qué medida considera que sería útil disponer de indicadores FAIR agregados a nivel sectorial o nacional (por ejemplo, pérdida anual esperada del sector en porcentaje de PIB)?

- Nada útil
- Moderadamente útil
- Muy útil

11.3 ¿Estaría su organización dispuesta a contribuir, de forma anonimizada, a un esfuerzo nacional para construir indicadores FAIR de país?

- No
- Tal vez, con garantías adecuadas
- Sí

12. Reflexión final

12.1 En su opinión, ¿qué es lo más difícil de cuantificar con FAIR en su organización?

- Frecuencias de incidentes
- Impactos económicos directos
- Impactos reputacionales y de mercado
- Sanciones y costes regulatorios
- Eficacia real de los controles
- Otros (especificar)

12.2 Si el Gobierno o el regulador le pidiera un indicador anual de “pérdida económica esperada por ciber-riesgo” de su organización, ¿cómo se sentiría?

- Sereno, ya lo tenemos calculado
- Preocupado, habría que improvisar mucho
- Francamente aterrorizado

12.3 Comentarios adicionales o confesiones anónimas sobre FAIR, el ciber-riesgo o la vida en general.

- Respuesta abierta.